盾语 • 银行 AI 智能体

安全自评报告

权限分级实现说明 + 已知风险清单

项目	内容
作品	盾语 · 银行 AI 智能体（仿真环境）
适用范围	本地演示 / 评审复现；不连接真实银行
结论	三级权限、确认/强验证、哈希链审计可现场复现；残余风险已列出

1. 权限分级实现

级别	范围	触发	实现
绿	余额、流水、账单、持仓、知识咨询、主动提醒	不涉及资金/状态变更	直接执行；policy.py green；无确认
黄	≤5,000 转账、退订、风险测评、调额、虚拟卡	写操作但可逆/低金额	确认卡（金额/对象/后果/params_hash/token/倒计时）
红	>5,000 转账、挂失、解挂、赎回、还款、密码重置链接	资金流出/不可逆	还款/信用卡/赎回：确认卡→MFA；其余红色：摘要→MFA；密码修改恒拒绝

补充规则：日累计 1,000 元、单笔 5 万元硬上限、新收款人 500 元、IM 300 元；LOCKED、风险分 >90、计划净流出超限 → deny；注入/角色伪装/第三人称查询 → 前置拒绝。

2. 安全机制与证据

机制	实现	证据
参数绑定	params_hash + token + intent_id + 过期	改金额 E_PARAM；改 token E_CONFIRM_TOKEN
审计哈希链	prev_hash 串联，SHA-256	改一行 payload → chain_ok=false
注入防护	前置规则 + 不可信内容包裹	红队 58/58
权限边界	policy.py 三级矩阵 + validator 七条	60/60
失败补偿	逆序 compensate	注入 create_standing_plan 失败 → freeze released
熔断	3 次 OBSERVE / 5 次 LOCKED 15 分钟	stepup 连续失败测试

现场复现：设置 → 安全证据，三个按钮分别在隔离临时库运行；首屏欢迎卡也有“亲手验证一次”入口。

3. 已知风险清单

风险	现状	缓解/边界
非真实 KYC/活体	模拟 L2 实名、设备指纹	生产接公安/人脸 SDK；文档明确仿真
强验证因子	短信码 + 人脸模拟，演示码 123456	生产替换短信网关/活体/U 盾；不改编排
复杂条件 DAG	单条件模板 + and + else	文档标注；复杂场景转人工
其他红色动作	摘要 + MFA，非独立确认卡	下一版统一状态机
多轮指代	覆盖上轮/改金额/全部展示	通用 DST 待做
Key 下发前端	确认 token 含一次性凭证	生产改 HttpOnly Cookie/二次签名
LLM 模式	默认关闭；失败回退	零 Key 演示不受影响
知识库	关键词+向量混合；无文档解析/重排	文档标注能力边界

4. 残余风险与诚实声明

- 项目是仿真 Demo，不连接真实银行核心，不产生真实资金。
- 已知 3 条检测层绕过未执行，靠策略兜底；不声称 100% 检出。
- 盲测 27/30，3 条失败公开保留；不拿盲测结果回头调规则。
- 人脸/U 盾为模拟或未实现；生产需替换 StepUpAuthProvider。
- 安全不是“模型更聪明”，而是确认、策略、执行、审计四层都不允许模型越权。

5. 复跑

```
cd backend
python -m unittest discover tests -q      # 448 项
python -m eval.runner                     # 243 条
python -m eval.blind_runner               # 30 条盲测
```